MÒDUL 06 · SEGURETAT INFORMÀTICA — RA3 · NF3-AA3

Criptografia

Del Codi Cèsar a l'AES: com protegim la confidencialitat i la integritat

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Xifrat simètric i asimètric

Dues famílies d'algorismes amb avantatges i inconvenients complementaris.



Diffie-Hellman i híbrida

Com s'intercanvien claus de manera segura sense transmetre-les mai directament.



Funcions hash

Com es garanteix la integritat d'un missatge o fitxer amb un resum de mida fixa.

HO SABIES?

Una ciència mil·lenària, encara vigent

Del Codi Cèsar a Enigma

Durant segles, la criptografia ha protegit missatges de mirades indiscretes: des del Codi Cèsar de l'antiga Roma fins a la màquina Enigma alemanya de la Segona Guerra Mundial.

Xifrar ≠ codificar

Una codificació (com Base64) NO assegura la confidencialitat: només representa la informació amb un alfabet diferent. Qualsevol pot decodificar-la; per protegir-la de debò cal xifrar-la.

DEFINICIONS BÀSIQUES

Xifrat, desxifrat i seguretat

- Xifrat: transformar un missatge llegible (text pla) en un d'inintel·ligible (text xifrat), mitjançant un algorisme i una clau. El desxifrat fa el procés invers.
- Seguretat incondicional (rar, exemple: xifrat de Vernam) vs. seguretat condicional (la majoria dels sistemes actuals, com AES): segurs amb la tecnologia actual, però potencialment trencables en el futur.

PRIMERA FAMÍLIA

Criptografia de clau simètrica

La mateixa clau s'utilitza per xifrar i desxifrar. Emissor i receptor han de conèixer-la i mantenir-la en secret.



Avantatges

Assegura la confidencialitat; algorismes ràpids; el text xifrat és més curt que amb clau pública. Algorismes: AES, DES/3DES, RC4, Blowfish. AES-256 és l'estàndard recomanat.



Inconvenients

Com intercanviar la clau a distància de forma segura? No garanteix la integritat ni el no-rebuig: qui coneix la clau pot modificar el missatge i tornar-lo a xifrar.

SEGONA FAMÍLIA

Criptografia de clau pública

S'utilitza un parell de claus matemàticament relacionades: la pública (es xifra amb ella) i la privada (només amb ella es pot desxifrar). Soluciona el problema de l'intercanvi de claus.

Avantatges

Resol l'intercanvi de claus; permet la signatura digital i l'autenticació. Algorismes: RSA, DSA, ElGamal, corba el·líptica (ECC).

Inconvenients

Algorismes més lents; claus i missatges xifrats més llargs que amb clau simètrica.

EL MILLOR DELS DOS MONS

Criptografia híbrida i Diffie-Hellman

- En la pràctica es combinen tots dos tipus: es xifra el missatge amb un algorisme simètric ràpid, usant una clau de sessió; l'intercanvi d'aquesta clau es fa amb un algorisme de clau pública.
- Avui, l'intercanvi de la clau de sessió es fa amb l'algorisme de Diffie-Hellman: genera una clau compartida sense transmetre-la mai directament (es calcula independentment a cada extrem).



Diffie-Hellman aplica "forward secrecy": si un atacant obté la clau privada d'un participant, no podrà calcular claus de sessió PASSADES, ja que aquestes s'esborren de la RAM un cop acaba la sessió.

PRÀCTICA REAL

Xifrat simètric amb OpenSSL (AES-256)

- OpenSSL és una eina de línia de comandes present a qualsevol sistema Linux, i disponible també per a Windows.

"openssl enc -aes-256-cbc -pbkdf2 -salt -in missatge.txt -out missatge.enc -pass pass:..." xifra un fitxer amb AES-256 i una contrasenya. El resultat és binari i il·legible fins que es desxifra amb la mateixa contrasenya ("-d"). Practicareu aquesta ordre a l'exercici guiat, amb captures reals del procés.

GARANTIR QUE NO S'HA MODIFICAT

Control d'integritat: funcions hash

- Una funció de hash (resum) genera un conjunt de bits de mida FIXA per a qualsevol entrada, independentment de la seva llargada.
- Ha de complir: 1) és fàcil calcular el resum a partir del missatge; 2) és impossible obtenir el missatge a partir del resum; 3) dos missatges diferents no haurien de generar el mateix resum (col·lisió).



MD5 i SHA-1 estan OBSOLETS: s'hi han trobat vulnerabilitats de col·lisió. Avui s'usen SHA-256 i SHA-512.

USOS PRÀCTICS DEL HASH

On trobem les funcions hash cada dia



Verificar descàrregues

Comparar el hash d'un fitxer descarregat (per exemple, una ISO d'Ubuntu) amb el hash publicat pel desenvolupador.



Contrasenyes

Es desa el hash de la contrasenya, no la contrasenya mateixa: en iniciar sessió, es recalcula i es compara.



Signatura digital

La signatura (amb clau privada) s'aplica sobre el HASH del document, no sobre l'original: ho veurem al proper AA.



HMAC: combina el resum amb una clau secreta compartida, afegint autenticitat de l'emissor a més d'integritat.

PRÀCTICA REAL

Signatura digital amb OpenSSL: signar i verificar

- 1) Es genera un parell de claus RSA. 2) Es signa el hash SHA-256 d'un document amb la clau PRIVADA. 3) Qualsevol pot verificar la signatura amb la clau PÚBLICA.

"openssl dgst -sha256 -sign clau_privada.pem -out doc.sig doc.txt" signa; "openssl dgst -sha256 -verify clau_publica.pem -signature doc.sig doc.txt" verifica: retorna "Verified OK" si el document no s'ha tocat, o "Verification failure" si s'ha modificat des que es va signar.

PER ACABAR

Idees clau d'avui



Simètric vs. asimètric

Ràpid però amb el problema de l'intercanvi de claus, vs. lent però que soluciona aquest problema i permet signar.



Diffie-Hellman

La solució pràctica: negociar una clau de sessió compartida sense transmetre-la mai directament.



Hash = integritat

SHA-256/512 permeten detectar si un fitxer o missatge ha estat modificat, sense revelar-ne el contingut original.

ARA ÉS EL TORN VOSTRE



Una empresa envia contractes signats digitalment als seus clients per correu electrònic.

En parelles: expliqueu, pas a pas, què passaria si un atacant intercepta el contracte i en modifica una xifra abans que el client el verifiqui. El client, podria detectar-ho? Per què?

10 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF3-AA3: Criptografia

Repositori "Materials" (GitHub, SMX-0226SI) · Carlos Alonso Martínez, Escola Pia de Mataró · Llicència CC-BY-SA-4.0

Practical Networking — Cryptography

practicalnetworking.net/series/cryptography/cryptography

DCODE — Codi de rotació o de Cèsar

dcode.fr/rot-cipher

OpenSSL

openssl.org

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró